

Министерство науки и высшего образования Российской Федерации
федеральное государственное автономное образовательное учреждение
высшего образования «Национальный исследовательский университет
ИТМО»

Факультет программной инженерии и компьютерной техники

Лабораторная работа №1 по предмету

"Информационная безопасность"

"Разработка защищенного REST API с интеграцией в CI/CD"

Выполнил:

Федоров Евгений Константинович

Группа: P3410

Санкт-Петербург,

2026

Оглавление

<i>Инициализация проекта.....</i>	<i>2</i>
<i>Описание проекта.....</i>	<i>2</i>
<i>Список эндпоинтов</i>	<i>2</i>
<i>Защита от SQL-инъекций.....</i>	<i>5</i>
<i>Защита от XSS-атак</i>	<i>5</i>
<i>Реализация аутентификации пользователя</i>	<i>6</i>

Инициализация проекта

Для данного проекта был создан репозиторий Git и был связан с репозиторием на GitHub.
Ссылка на репозиторий: https://github.com/2BuRy1/information_security_lab_1

Описание проекта

В данной работе было реализовано REST API приложение с поддержкой аутентификацией при помощи JWT-токена. У аутентифицированных пользователей есть возможность просмотра других зарегистрированных в системе пользователей, отправки им сообщений по логину и просмотра собственных сообщений.

Список эндпоинтов

- POST auth/register – регистрация

Формат запроса:

```
{
  "login": "alice",
  "password": "alicepass",
  "repeatedPassword": "alicepass"
}
```

Формат ответа:

```
{  
  "token": "some_tome"  
}
```

- POST auth/login – вход

Формат запроса:

```
{  
  "login": "alice",  
  "password": "alicepass",  
}
```

Формат ответа:

```
{  
  "token": "some_tome"  
}
```

- GET api/data – получение списка зарегистрированных пользователей

Формат ответа:

```
[  
  {  
    "id": 53,  
    "login": "bob"  
  }  
]
```

- POST `api/messages` – отправить сообщение

Формат запроса:

```
{  
  "recipient": "bob",  
  "text": "hey, bob!"  
}
```

Формат ответа:

```
{  
  "id": 1,  
  "from": "alice",  
  "to": "bob",  
  "text": "hey, bob",  
  "createdAt": "2026-09-15T21:42:48.60984"  
}
```

- GET `api/message` – получить все сообщения

Формат ответа:

```
[  
  {  
    "id": 1,  
    "from": "alice",  
    "to": "bob",  
    "text": "hey, bob",  
    "createdAt": "2026-09-15T21:42:48.60984"  
  }  
]
```

Защита от SQL-инъекций

Защита от SQL-инъекций обеспечивается использованием Spring Data JPA поверх Hibernate. Все обращения к БД идут через методы репозитория, которые Hibernate транслирует в параметризованные подготовленные запросы (PreparedStatement) согласно спецификации JPA. Конкатенации строк при построении SQL в проекте нет ни в одном месте, пользовательские данные всегда передаются как связанные параметры, а не встраиваются в текст запроса.

Защита от XSS-атак

Приложение является чистым REST API и не генерирует HTML: все ответы отдаются в формате application/json и сериализуются библиотекой Jackson, входящей в Spring Boot. Jackson при сериализации экранирует специальные и управляющие символы (кавычки, переводы строк и т.д.) по правилам JSON, поэтому пользовательские данные (логины, тексты сообщений) не могут «вырваться» за пределы строкового значения и изменить структуру ответа. Поскольку браузер не исполняет контент с типом application/json, внедрённый в поля скрипт не выполняется сам по себе; экранирование при отображении возлагается на клиент (современные фреймворки типа React экранируют по умолчанию).

Реализация аутентификации пользователя

В работе используется JWT access-токен. Access-токен служит для доступа к защищённым эндпоинтам: именно по нему определяется пользователь. Время жизни токена — 1 час, токен подписывается алгоритмом HS256 секретным ключом.

Токен выдаётся при регистрации POST /auth/register и при входе POST /auth/login.

На защищённых эндпоинтах стоит фильтр - он проверяет наличие и формат заголовка Authorization: Bearer <токен>, проверяет подпись и срок действия, загружает пользователя из БД и устанавливает аутентификацию.

В базе данных пароли хранятся только в виде хэшей bcrypt, сырые пароли нигде не сохраняются и не логируются.

Полученные отчеты по SAST/SCA из Actions

SAST:

```
1  ► Run mvn -B -ntp spotbugs:check
7  [INFO] Scanning for projects...
8  [INFO]
9  [INFO] -----< com.security:lab >-----
10 [INFO] Building lab 0.0.1-SNAPSHOT
11 [INFO]    from pom.xml
12 [INFO] -----[ jar ]-----
13 [INFO]
14 [INFO] >>> spotbugs:4.9.3.0:check (default-cli) > :spotbugs @ lab >>>
15 [INFO]
16 [INFO] --- spotbugs:4.9.3.0:spotbugs (spotbugs) @ lab ---
17 [INFO] Fork Value is true
18 [INFO] Done SpotBugs Analysis....
19 [WARNING] Unable to find a URL to the parent project. The parent menu will NOT be added.
20 [INFO] Rendering content with org.apache.maven.skins:maven-fluido-skin:jar:2.0.0-M9 skin
21 [INFO]
22 [INFO] <<< spotbugs:4.9.3.0:check (default-cli) < :spotbugs @ lab <<<
23 [INFO]
24 [INFO]
25 [INFO] --- spotbugs:4.9.3.0:check (default-cli) @ lab ---
26 [INFO] BugInstance size is 0
27 [INFO] Error size is 0
28 [INFO] No errors/warnings found
29 [INFO] -----
30 [INFO] BUILD SUCCESS
31 [INFO] -----
32 [INFO] Total time:  14.285 s
33 [INFO] Finished at: 2026-09-15T20:31:59Z
34 [INFO] -----
```

SCA:

```
284 Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and there
285 are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of
286 this tool, the analysis performed, or the resulting report.
287
288 About GDC: https://jeremylong.github.io/DependencyCheck/general/infomails.html
289 False Positives: https://jeremylong.github.io/DependencyCheck/general/suppression.html
290
291 Sponsor: https://github.com/sponsors/jeremylong
292
293 [INFO] Analysis Started
294 [INFO] Finished Archive Analyzer (8 seconds)
295 [INFO] Finished File Name Analyzer (8 seconds)
296 [INFO] Finished Jar Analyzer (8 seconds)
297 [INFO] Finished Dependency Merging Analyzer (8 seconds)
298 [INFO] Finished Hint Analyzer (8 seconds)
299 [INFO] Finished Version Filter Analyzer (8 seconds)
300 [INFO] Created CPE Index (1 seconds)
301 [INFO] Finished CPE Analyzer (3 seconds)
302 [INFO] Finished False Positive Analyzer (8 seconds)
303 [INFO] Finished NVD CVE Analyzer (8 seconds)
304 [INFO] Finished RetireJS Analyzer (8 seconds)
305 [INFO] Finished Vulnerability Suppression Analyzer (8 seconds)
306 [INFO] Finished Known Exploited Vulnerability Analyzer (8 seconds)
307 [INFO] Finished Dependency Bundling Analyzer (8 seconds)
308 [INFO] Finished Unused Suppression Rule Analyzer (8 seconds)
309 [INFO] Analysis Complete (5 seconds)
310 [INFO] Writing HTML report to: /home/runner/work/information_security_lab_1/information_security_lab_1/lab/target/dependency-check-report.html
311 [INFO] Writing JSON report to: /home/runner/work/information_security_lab_1/information_security_lab_1/lab/target/dependency-check-report.json
312 [WARNING]
313
314 One or more dependencies were identified with known vulnerabilities in lab:
315
316 angular-activation-2.8.3.jar (pkgs:mvn/org.eclipse.angus/angus-activation@2.8.3, cpe:2.3|eclipse:angus_mail@2.8.3|*:*:*:*:*:*|) : CVE-2025-7962
317 tomcat-embed-core-11.0.24.jar (pkgs:mvn/org.apache.tomcat.embed/tomcat-embed-core@11.0.24, cpe:2.3|apache:tomcat:11.0.24|*:*:*:*:*:*|) : CVE-2026-65637, CVE-2026-65985, CVE-2026-65182, CVE-2026-68525, CVE-2026-65183, CVE-2026-
318 66422, CVE-2026-68565, CVE-2026-6927, CVE-2026-68763, CVE-2026-73188, CVE-2026-66299
319
320 See the dependency-check report for more details.
321
322
323 [INFO] -----
324 [INFO] BUILD SUCCESS
325 [INFO] -----
326 [INFO] Total time: 33:28 min
327 [INFO] Finished at: 2026-09-25T21:05:23Z
328 [INFO] -----
```